SA8 Secure Integration Architecture Case

Student: Laurence Matthew B Manuel **Section:** BSIT 3A **Project:** Project 29 Thesis Consultation Reminder System
Milestone: Week 14 v2.0.0 **Completed:** 8 November 2026 Asia/Manila

Executive conclusion

The Week 13 consultation workflow now has a bounded secure-exchange architecture that combines certificate-validated HTTPS, expiring authentication, server-enforced roles and ownership, minimized records, AES-256-GCM authenticated encryption, protected server-only keys, safe structured logs, and durable replay rejection. Actual backend, HTTPS, TLS and browser evidence supports the controlled local prototype. It does not support a claim of production readiness, nonrepudiation, encrypted database storage, or completed institutional security approval.

Threat summary

Threat	Asset and path	Control	Verified outcome	Residual risk
Credential or token interception	Login/session across browser network	Trusted HTTPS, no URL tokens, in-memory Flutter token, hashed server session, no-store response	Browser operated on HTTPS; TLS 1.3 verified	Endpoint or live session compromise remains possible.
Unauthorized role or cross-assignment access	Consultations and decrypted record	Session middleware, role checks, recipient ID and adviser assignment	Panel/other adviser rejected 403	Administrator/database compromise bypasses application checks.
Ciphertext or metadata modification	Envelope in transfer	AES-256-GCM tag over ciphertext and canonical metadata	Altered ciphertext/recipient rejected 422; no receipt	Shared-key compromise permits forgery.
Replay	Previously valid envelope	UUID, five-minute TTL, unique database receipt	Second submission rejected 409; one receipt	Distributed receivers would need a shared replay store.
Stale message	Captured envelope after its purpose	Authenticated issue/expiry times, bounded future skew	Authentic expired envelope rejected in clock-controlled test	Clock drift can cause false rejection or reduced freshness.
Key disclosure	Source, Flutter, logs, screenshots, backups	Ignored server keyring, blank example, no key logging, actual-key comparison	Protected paths ignored; logger test passed	Local account/host compromise can expose file.
Invalid endpoint certificate	Browser-to-gateway connection	Local CA, localhost SAN, certificate validation, no warning bypass	Controlled CA succeeds; absent CA rejects	Lab CA has no online revocation service.
Diagnostic leakage	Validation and security events	Generic 5xx, correlation ID, allowlisted metadata	Saved results contain outcomes, not token/key/ciphertext	Fictional agenda remains visible to authorized browser users.
Dependency or gateway error	TLS-to-API integration	Safe client feedback, explicit CORS allowlist, regression test	Initial browser failure preserved; corrected preflight and rerun succeeded	Custom evidence gateway is not a production proxy.

Protection requirements and data flow

The full protection matrix is in `docs/protection-requirements.md`. The editable and exported diagrams are `diagrams/secure-data-flow.json`, `.mmd`, `.svg` and `diagrams/secure-exchange-sequence.json`, `.mmd`, `.svg`. They identify the browser/public-client boundary, TLS termination, Laravel authorization, server-only keyring, workflow database, replay receipt, safe error path and allowlisted audit path.

The exchanged plaintext is limited to record type, consultation ID, agenda, scheduled time, status, and open-action count. Names, email addresses, roles, session tokens, action-item text, audit records and automation history are excluded. Encryption is not used to justify collecting more data.

Control choice and alternatives

AES-256-GCM through installed PHP OpenSSL was selected over unavailable Sodium XChaCha20-Poly1305 and over a higher-complexity asymmetric hybrid. TLS-only was rejected as the complete answer because it does not meet the authenticated-payload exercise or independently demonstrate tamper/replay handling. The architecture keeps TLS because the envelope does not protect credentials, session tokens or server identity.

The design uses a 256-bit key, 96-bit random nonce, 128-bit tag, authenticated version/key/message/time/sender/recipient metadata, a five-minute lifetime, 30-second future skew, and a database unique constraint. The control rationale and misuse warnings are in `docs/control-rationale.md`; the decision and disadvantages are in `docs/cryptographic-decision.md`.

Key lifecycle and configuration

`php artisan secure-exchange:key` provisions an ignored keyring without printing the key. `--rotate` creates a new active key and retains only the previous key for the bounded in-flight period. The local TLS CA and server keys are separate and short-lived. The tracked `.env.example` contains only blank values and protected-path configuration. Loss, compromise, backup, recovery, previous-key removal, CA removal and production migration are covered in `docs/key-lifecycle.md`.

Verification summary

- Backend: 21 tests and 199 assertions pass, including normal acceptance, tamper, authenticated-metadata change, replay, expiry, invalid input, unauthorized roles, wrong key, missing key recovery, and safe log content.
- HTTPS API: 5 of 5 actual cases pass at 20:37 Asia/Manila on 8 November 2026.
- TLS: TLS 1.3 and `TLS_AES_256_GCM_SHA384` negotiated; missing trust anchor rejected.
- Flutter: analysis reports no issues; 18 widget/unit tests pass at desktop, tablet and narrow widths, including secure sender/receiver and malformed-envelope states; release web build succeeds with the HTTPS API URL.
- Browser: coordinator envelope creation, assigned-adviser receipt and visible replay rejection were captured over `https://localhost:8444` with fictional data.
- Initial failure: the first TLS browser login exposed missing CORS preflight forwarding. The safe failure, narrow fix and successful rerun are retained in Activity 2.

Residual risk and recommendation

The prioritized risks are documented in `docs/residual-risk-register.md`. The largest remaining risks are local host/key compromise, shared-key forgery, live session theft, the lab CA lifecycle, plaintext loopback proxying, time drift and incomplete manual assistive-technology review.

The architecture is acceptable for the controlled Week 14 assessment and continued course development. Before broader use, replace the evidence gateway with a maintained deployment proxy, move secrets to an approved protected store, add session revocation and idle expiry, monitor time and security events, define receipt retention, conduct manual accessibility/security review, and assign certificate/incident owners.

Assessment and defense notes

The concept check is supported by Activity 1. The guided build is supported by the Laravel/Flutter source, configuration example and browser evidence. The adverse test is supported by the initial CORS failure, tamper/replay/authorization/TLS results and recovery. The technical portfolio includes decision records, diagrams, tests, limitations and maintenance instructions. Actual instructor questioning, marks and acceptance remain external and are not claimed.

Acknowledgment

This work uses Laravel, Flutter, PHP OpenSSL, Python cryptography, Mermaid and official framework/runtime behavior. AI assistance supported code implementation, verification, diagrams and drafting. Exact institutional acknowledgment wording remains subject to instructor guidance.